



TLPT Lifecycle (TIBER-EU Context)

STRUCTURED APPROACHES TO THREAT-LED PENETRATION TESTING
WITHIN THE TIBER-EU FRAMEWORK



Introduction to TLPT and TIBER-EU

TLPT mimics tactics of real-world attackers

- Reflects actual risks over theoretical vulnerabilities

Intelligence-driven approach unique to each organization

- Tailored to the threat landscape faced by the business

TIBER-EU provides standardized testing methodology

- Recognized for rigorous, harmonized approach

Enables benchmarking and cyber resilience improvement

- Supports national and cross-border organizations

Overview of TLPT Lifecycle Phases

TLPT lifecycle is a sequence of interconnected phases

- Delivers robust assessments and organizational learning

Phases include planning, intelligence, testing, and review

- Steps are planning, gathering, red team, blue team, analysis, remediation, enhancement

Drives continuous improvement in security and resilience

- Encourages learning beyond technical assessment

Each phase has distinct objectives and outcomes

- Supports both business and regulatory needs

Planning and Scoping Phase

Defines scope, objectives, and engagement rules

- Sets foundational boundaries for the exercise

Involves stakeholders across business domains

- Includes risk, compliance, and technical teams

Identifies critical functions and assets

- Examples: payments, account management, trading platforms

Balances business priorities and regulatory needs

- Focuses on realistic, high-impact areas



Threat Intelligence Gathering and Analysis

Actionable intelligence distinguishes TLPT from traditional tests

- Relies on tailored, up-to-date threat information

Independent provider conducts deep-dive threat analysis

- Reviews attacker campaigns, profiles, tools, sector threats

Intelligence reflects organization's unique risks

- Contextualizes regional and process-specific threats

Guides red team scenarios via adversary emulation plans

- Directs focus to relevant attacker tactics



Red Team Testing Phase

Red team emulates real-world advanced attackers

- Attempts to compromise agreed critical assets

Operates under strict safety and engagement rules

- Minimizes risk and disruption

Uses latest observed tactics and adaptive techniques

- Includes social engineering, spear-phishing, zero-days

Documents all actions and defensive responses

- Records each step's success or failure





Blue Team Detection and Response

Blue team operates independently during the test

- Often unaware of specific red team activities

Responsible for detection and incident response

- Must identify and mitigate malicious actions

Trusted individuals may be informed to ensure realism

- Maintains authentic response environment

Performance reveals gaps or strengths in defenses

- Outcomes drive further analysis

Analysis and Reporting Phase

Collaborative analysis brings all teams and stakeholders together

- Red team, blue team, intelligence, business stakeholders participate

Deliver actionable reports with scenarios, techniques, and results

- Documents breaches, near-misses, and detection points

Translate technical findings into business impacts

- Communicates risks to management and board

Root cause assessment identifies deeper issues

- Highlights process, technology, or culture gaps



Remediation and Retesting Phase

Prioritize and assign remediation actions to teams

- Technical fixes and process improvements included

May require follow-up testing for critical issues

- Ensures gaps have been addressed

Improvements go beyond technology to training and third-party management

- Enhances response playbooks and vendor controls

Continuous learning is central under TIBER-EU

- Retesting validates progress after remediation



Lessons Learned and Strategic Enhancement

Senior leadership uses findings for strategic improvements

- Involves leaders beyond technical teams

TLPT insights inform organizational strategy and processes

- Drives changes in procurement or onboarding if needed

Detects skill gaps and informs training investments

- Response failures addressed by targeted development

Reviews program effectiveness for continuous improvement

- Considers scope, intelligence quality, and impact



TLPT Real-World Example: European Bank

Bank chooses TIBER-EU compliant TLPT for online banking risks

- Prioritizes payments and customer data protection

Threat intelligence reveals state-sponsored attack patterns

- Includes phishing and supply chain compromises

Red team simulates real attacks based on gathered intelligence

- Phishing, exploitation, and privilege escalation attempted

Bank improves monitoring, training, and vendor controls post-exercise

- Retest shows critical gaps addressed

Common TLPT Implementation Challenges

Resource constraints worsen TLPT complexity

- Budget and skilled staff may be limited

Requires detailed coordination and executive buy-in

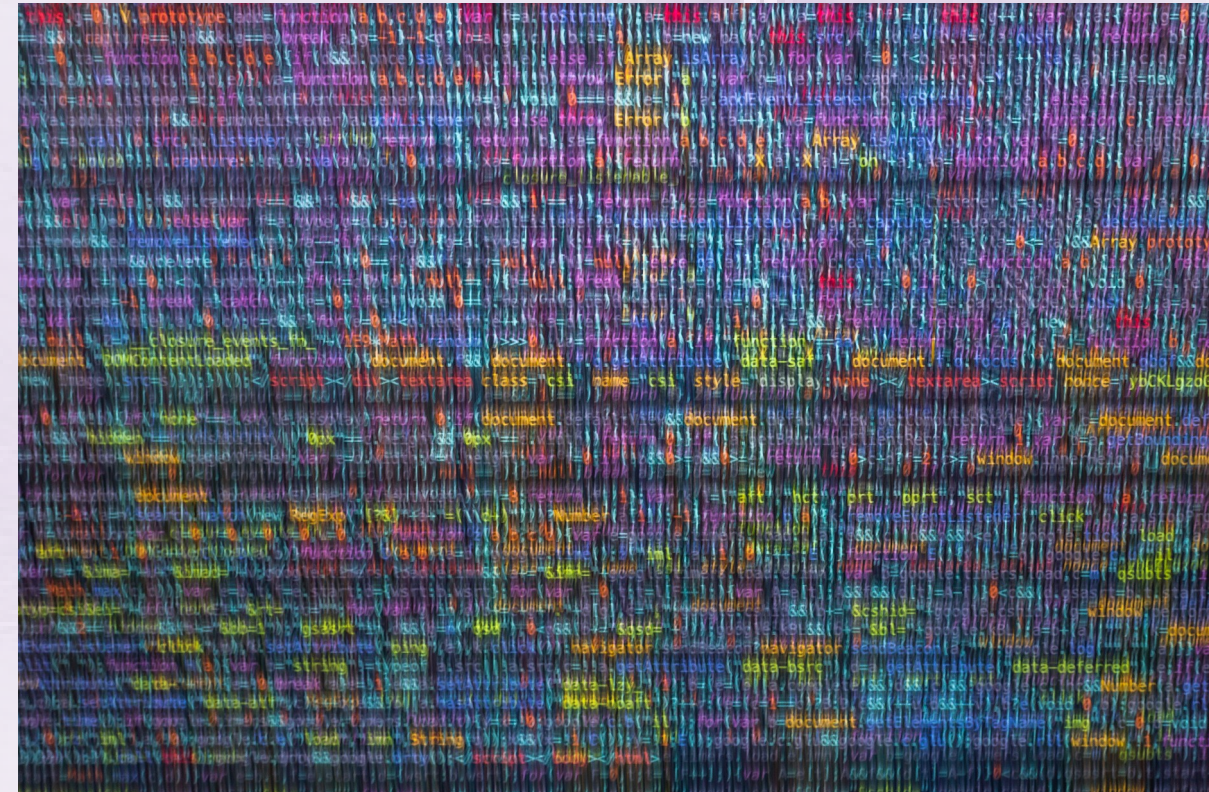
- Often involves phased or targeted testing

Must balance attack realism with business safety

- Scoping and engagement rules manage risks

Cultural resistance can hinder learning culture adoption

- Leadership and communication are key



Embedding TLPT into Risk Management

TLPT should not be treated as one-off compliance

- Drives real, sustained organizational change

Assign ownership and track remediation progress

- Integrate outcomes into board-level risk discussions

Regular TLPT supports ongoing cyber resilience strategy

- Embeds results into strategic planning

Ensures findings lead to continuous improvement

- Avoids shelving reports without action



Adapting to an Evolving Threat Landscape

Threat actors continually adapt their methods

- Past defenses may be outdated quickly

Maintain active relationships with intelligence providers

- Stay informed of current threats

Regular TLPT exercises suggested every 2 to 3 years

- Focus on critical functions' resilience

Rolling cadence tests business areas without overwhelming resources

- Alternates test focus across years

Long-Term Benefits of TLPT under TIBER-EU

Validates real-world resilience against likely adversaries

- Moves beyond checklists and theoretical tests

Satisfies regulatory requirements and builds stakeholder confidence

- Demonstrates effective risk management to external parties

Fosters cross-functional collaboration and cyber risk understanding

- Engages technical, business, and risk leaders

Promotes a culture of learning and continuous improvement

- Identifies and addresses systemic weaknesses



TLPT Lifecycle: Full-Spectrum Approach

Lifecycle spans planning to strategic enhancement

- Each phase adds unique, actionable value

Addresses technical, business, and regulatory imperatives

- Ensures insights for all organizational levels

Key challenges include resources, safety, and integration

- Handled with strong leadership and improvement commitment

Real-world cases prove TLPT's impact on resilience

- Drives measurable organization-wide change



Designing a Sustainable TLPT Program

Align cadence with business risk and regulations

- Once every 2 to 3 years for critical functions

Exercises must be driven by current, tailored intelligence

- Updates based on threat landscape and priorities

Findings must lead to clear actions and ownership

- Accountability ensures continuous improvement

Foster a culture of learning and growth, not blame

- Insights drive strategic, not just tactical, changes



Reflective Questions for TLPT Implementation

How does your current testing compare to TLPT?

- Consider TIBER-EU model differences

Are your tests truly intelligence-driven and risk-aligned?

- Evaluate test relevance to critical risks

Will lessons shape long-term strategy, not just fixes?

- Ensure insights guide organizational change

